

Maybank

One architecture, three regulators — designing for the strictest and relaxing by exception

A single CRM platform serving three ASEAN jurisdictions has to satisfy three supervisors simultaneously, not sequentially. The design rule that follows is counter-intuitive and expensive to discover late.



JURISDICTIONAL SCOPE · AS SET BY THE PROGRAMME

Distinct residency and sovereignty regimes · wholesale data physically separated · cross-border customer data ring-fenced per jurisdiction

Aditya Singh · Compliance-architecture analysis authored for solution design · 2026

Three supervisors must be satisfied at the same time by one architecture — which means the strictest requirement in scope becomes the design baseline for all three

Situation

One CRM platform serving a home market, a regional financial hub and a large neighbouring market, split across a consumer vertical and a wholesale vertical with different governance postures.

Each jurisdiction imposes its own residency, sovereignty and disclosure requirements on the same customer data model.

Complication

The requirements do not conflict in the sense of being mutually exclusive. They compound — each adds constraints the others do not, and the architecture has to hold all of them at once.

Worse, the binding ones are structural. Residency is a property of where data physically sits; changing it after go-live means migrating live production data under supervision, which no programme willingly does twice.

The design rule

Design to the strictest requirement in scope and relax by documented exception, never the reverse. Sequence go-lives so the hardest supervisor is engaged early rather than last.

And treat physical isolation of wholesale data as a fixed constraint filtered before any option is scored, not as a dimension available for trade.

THE NUMBERS THAT MATTER

3

regimes, one baseline

6

control domains mapped

1

constraint, never scored

2

verticals, one data model

0

residency retrofits available

1st

hardest regulator, first

Why the rule is counter-intuitive: designing for the easiest jurisdiction and generalising later looks cheaper and delivers the first go-live faster. It is the most expensive available order, because every subsequent market forces rework of something already in production and already inspected.

Requirements were set by the programme; the control mapping, the design rule and the sequencing argument are analysis — not legal or regulatory advice

SET BY THE BANK

Programme context

Jurisdictional constraints, vertical governance postures and the isolation requirement as stated by the programme.

- Three jurisdictions in scope
- Distinct residency regimes
- Wholesale physical isolation
- Cross-border ring-fencing
- Two verticals, one platform
- User distribution by market

ARCHITECTURE ANALYSIS

My contribution

The control-domain mapping, the compounding-versus-conflicting distinction, the design rule and the sequencing recommendation.

- Six-domain control map
- Compound-not-conflict analysis
- Strictest-baseline design rule
- Supervisor question set
- Go-live sequencing logic
- Evidence-pack design

DESIGN-LEVEL

Assessed

Regulatory requirements summarised at the level needed for architecture decisions, not as a legal analysis.

- Design-level requirement summary
- Control applicability by jurisdiction
- Relative strictness judgements
- Not a legal opinion
- Not a regulatory submission
- Confirm with counsel before filing

OUT OF SCOPE

Not claimed

Excluded deliberately. Architecture analysis, not compliance certification or a supervisory position.

- Any supervisor's actual position
- Regulatory approval or clearance
- Legal interpretation of any regime
- Delivery of this programme
- Any confidential bank document
- Post-decision outcomes

THE THREE REGIMES

Each supervisor constrains a different part of the same architecture — and the union of their requirements, not the intersection, is what has to be built

Home market supervisor

8,700 users

- Primary customer data resident in market
- Outsourcing and third-party risk notification
- Full audit trail available on request
- Incident reporting within defined windows
- Technology risk governance framework

Regional hub supervisor

1,060 users

- Strict personal-data protection regime
- Cross-border transfer requires lawful basis
- Individual access and correction rights
- Breach notification obligations
- Accountability and demonstrable governance

Neighbouring market supervisor

3,560 users

- Data localisation — in-country storage
- Electronic systems registration
- Local processing and access controls
- Sovereignty over customer records
- Constrains offshore hosting entirely

They compound, they do not conflict

- No two are mutually exclusive — nothing forces a choice of supervisor.
- But each adds constraints the others do not, so the architecture must hold the union of all three.
- That is a harder problem than a conflict, because a conflict at least gets escalated. A compounding set just quietly makes the design stricter.

One regime dominates the storage decision

- Localisation in the neighbouring market forbids offshore hosting for that market's data outright.
- It is therefore the binding constraint on topology, regardless of what the other two would permit.
- The architecture is shaped by that single requirement more than by any of the others.

Another dominates the process design

- The hub's personal-data regime drives consent, access rights, correction, retention and breach notification.
- These are process and data-model obligations rather than topology ones, and they apply to everything the platform touches.
- Building them everywhere costs less than building them once and retrofitting them twice.

Six control domains mapped across three jurisdictions — the strictest cell in each row becomes the design baseline for the whole row

Control domain	Home market	Regional hub	Neighbouring market	Baseline set by
Data residency	In-market for primary data	Transfer on lawful basis	In-country, no offshore	Neighbour
Consent and lawful basis	Sector rules apply	Explicit, purpose-bound, revocable	General protection regime	Hub
Access and correction rights	On request	Individual right, defined window	On request	Hub
Breach notification	Defined reporting window	Defined window to authority and subject	Defined reporting window	Hub
Isolation of wholesale data	Physical separation required	Physical separation required	Physical separation required	All three
Audit and evidence	Available on inspection	Demonstrable accountability	Local access for inspection	Hub + neighbour

How to read the last column

- It names which jurisdiction sets the design baseline for that control — not who is hardest overall.
- No single supervisor dominates the whole map, which is precisely why a per-market design fragments the platform.
- One row is set by all three, and that row is the non-negotiable.

What this map is actually for

- It converts three separate regulatory conversations into one design specification.
- It makes the strictest-baseline rule concrete rather than a principle — each row has a named source.
- It becomes the spine of the evidence pack presented to each supervisor.

Where teams get this wrong

- Building a compliance matrix per jurisdiction and then trying to reconcile three designs.
- That produces three architectures and three evidence packs.
- Mapping by control domain instead of by regulator is the move that keeps one platform.

Four architectural responses carry all six control domains — and three of the four are irreversible after the first go-live

Residency by topology IRREVERSIBLE Storage location fixed per jurisdiction at design time, with no cross-border replication of primary customer records. Processing follows storage. Changing it means migrating live production data under supervisory notice — a programme nobody runs twice.	Isolation by physical separation IRREVERSIBLE Wholesale data on its own application and database estate in every market. Never logically isolated, never co-mingled at storage. Retrofitting physical separation means splitting a live database and re-proving every interface built on it.
Policy as configuration, structure as constant REVERSIBLE One data model across all markets; jurisdictional difference expressed as consent, retention and access policy rather than as schema variation. Policy can be changed and re-approved. Schema divergence, once shipped, becomes three platforms.	Evidence generated, not assembled REVERSIBLE Audit trail, consent state and data lineage produced continuously by the platform rather than compiled for an inspection. Can be added later at cost, but every inspection before it is added is answered by hand.

Two of these are decided in the first design sprint and cannot be revisited. Sequencing design attention by reversibility, rather than by visibility, is the whole discipline.

Six questions decide the conversation — and each one is answered by an artefact the platform either produces or does not

Where has this customer's data been?

Not where it is now. Lineage across its whole life, including test environments and backups.

Continuous lineage record, environment-tagged

On what basis was it processed?

The lawful basis at the moment of each use, not a blanket consent captured at onboarding.

Purpose-bound consent, timestamped per use

Who could see it, and who did?

Entitlement design and actual access, distinguished. Both, for the retention period.

Entitlement model plus access log, joined

How do you know isolation holds?

Not the design intent — the evidence that no cross-boundary access has occurred.

Automated isolation tests in the release pipeline

What happens when it goes wrong?

The detection path, the notification clock, and evidence the clock has been met before.

Incident record with timestamped notification

Can you show me, now?

Whether the evidence is generated continuously or compiled after the request arrives.

Standing evidence pack, not a compilation exercise

Every one of the six is answered by an artefact, not by a statement. A platform that generates them continuously passes inspections; one that compiles them on request passes the first and struggles with the second.

Engage the hardest supervisor first — the instinct to start with the easiest market is the most expensive order available

THE COMMON ORDER

Easiest market first

- Fastest route to a first go-live and an early programme win
- Design shaped by the least demanding requirements in scope
- Second market forces rework of something already in production
- Third market forces it again, now with two live estates and two supervisors watching
- Each rework is a change to an inspected system, not to a design document

THE RECOMMENDED ORDER

Hardest supervisor engaged first

- Design baseline set by the strictest requirement before anything is built
- First go-live is slower and every subsequent one is faster
- Later markets relax by documented exception rather than by rework
- Each supervisor sees a design already meeting a stricter standard than its own
- One evidence pack, extended per market, rather than three assembled separately

01

Pre-engage on design

Present residency, isolation and evidence design to the strictest supervisor before build starts

02

Build to the baseline

Strictest requirement becomes the platform default across all markets

03

Home market go-live

Largest population, on a design already exceeding local requirements

04

Relax by exception

Later markets document where they need less, never where they need more

05

Extend the evidence pack

One pack, extended per jurisdiction, rather than three compiled separately

Four rules for one architecture across several jurisdictions

- | | | |
|----|--|---|
| 01 | Map by control domain, not by regulator | A compliance matrix per supervisor produces three designs to reconcile. A matrix per control domain, with the strictest cell naming the baseline, produces one platform and one evidence pack. |
| 02 | Design to the strictest, relax by exception | Requirements compound rather than conflict, so the architecture must hold their union. Building to the strictest and documenting where less is needed costs far less than the reverse. |
| 03 | Sequence design attention by reversibility | Residency and physical isolation cannot be revisited after go-live; policy and evidence can. Spend the first design sprint on the two that are permanent, not the two that demonstrate well. |
| 04 | Generate evidence, never assemble it | Every supervisory question is answered by an artefact. A platform producing lineage, consent state and access records continuously passes repeat inspections; one that compiles them on request does not. |

Three supervisors, one architecture, one evidence pack. The alternative is not three architectures — it is one architecture reworked twice, under inspection, after it is already live.